LITERATURE SURVEY

Trust-Aware Agentic AI for Autonomous Cyber Incident Response and Resilient Recovery

Project ID	Course	Review
221	UE24CS320A – Capstone Project	Phase-I · Review-1
Project Guide	**Institution**	**Survey focus**
Dr. Geetha Dayalan	PES University	AI-assisted incident response

Research Paper Under Review
“Advancing Autonomous Incident Response: Leveraging LLMs and Cyber Threat Intelligence”
Authors: Amine Tellache, Abdelaziz Amara Korba, Amdjed Mokhtari, Horea Moldovan, and Yacine Ghamri-Doudane.
Publication: 2025 IEEE Global Communications Conference (GLOBECOM 2025).
DOI: 10.1109/GLOBECOM59602.2025.11432623.
Preprint reviewed: arXiv:2508.10677v1, 14 August 2025.

Abstract of the Survey

This survey reviews a RAG-based incident-response framework that combines large language models with cyber threat intelligence. The system enriches security alerts through structured queries to external CTI platforms and semantic retrieval from a CTI document collection, then generates contextual incident-mitigation strategies. The paper is relevant to Team 221 because it demonstrates how incident evidence and threat intelligence can be combined to support response planning. However, it does not present a recovery-point trust model or a dependency-aware enterprise restoration workflow.

1. Problem Addressed

Security operations teams process large volumes of alerts and must distinguish meaningful threats from false positives. Alert triage and enrichment require analysts to extract indicators of compromise, search threat-intelligence sources, compare current events with historical campaigns, and prepare appropriate response actions. Cyber Threat Intelligence (CTI) is useful for this work, but CTI reports are extensive, fragmented, and often unstructured. Manually searching and correlating them can delay response and increase analyst workload.

The paper addresses the challenge of making CTI usable during incident response without repeatedly fine-tuning a language model whenever new threat information becomes available. Its objective is to enrich SIEM alerts with dynamically retrieved CTI and use the augmented context to generate actionable response strategies.

2. Research Methodology

The authors propose a Retrieval-Augmented Generation (RAG) architecture with two main phases: retrieval and augmented generation. In the retrieval phase, the system first extracts indicators of compromise from an alert and queries external CTI services. It then searches a vector database containing chunks of CTI reports using embedding similarity. In the generation phase, the original alert and retrieved intelligence are combined in a prompt supplied to a pre-trained language model, which generates an incident response strategy.

The CTI knowledge base is built by extracting text from PDF reports, cleaning and splitting the text into chunks, converting chunks into embeddings, and storing them in a vector database. New CTI can be incorporated by updating the knowledge base rather than fine-tuning the LLM for each update.

2. Research Methodology (continued)

Research component	Description
Alert input	SIEM alert or incident description is supplied to the RAG workflow.
IOC extraction	An IOC parser extracts domains, hashes, IP addresses, and URLs from alert data.
Structured CTI lookup	External CTI APIs, including VirusTotal in the reported experiments, return contextual information such as reputation and historical malicious activity.
CTI document retrieval	CTI reports are converted to text, chunked, embedded, and searched using semantic similarity in a vector database.
Response generation	A prompt combines the alert and retrieved context; a pre-trained GPT model generates a tailored response strategy.
Evaluation	Automated LLM scoring is cross-validated using expert assessment on controlled simulated alerts.

3. Technologies and Analytical Techniques

The paper's implementation combines security monitoring, threat-intelligence retrieval, vector search, and LLM-based text generation. The authors report using LogPoint SIEM for real alerts; an ELK-based SIEM in the controlled environment; Elastic Defend agents on Windows and Linux hosts; Proxmox to host virtual machines; and MITRE Caldera to emulate attack techniques mapped to MITRE ATT&CK.; VirusTotal is queried through its API for IOC context. PyMuPDF extracts text from CTI PDFs, and Chroma stores embedded document chunks. Transformer-based embeddings and cosine similarity support semantic retrieval. GPT-4o is used for response generation.

The evaluation uses Mistral-large-2407, Llama-3.1-70B-Instruct, and Llama-3.2-3B-Instruct as automated evaluators. The three evaluation dimensions are answer relevance, context relevance, and groundedness, each scored on a five-point scale.

4. Experimental Setup

The real-world evaluation uses 100 enterprise SIEM alerts randomly selected from 10 August to 8 September 2024. The simulated evaluation uses 10 alerts produced in an isolated Proxmox environment containing attacker, Windows victim, Ubuntu victim, and SIEM virtual machines. Caldera is used to emulate selected adversary behaviours, and SIEM detection rules generate alerts from the resulting events. The CTI document collection is drawn from publicly available APT and cybercriminal-campaign reports.

5. Key Findings and Results

For the 100 real-world alerts, the paper reports strong answer-relevance and groundedness scores. Mistral-large-2407 gives a mean answer-relevance score of 4.97/5 and groundedness of 4.53/5. The combined VirusTotal-plus-CTI context-relevance score for this evaluator is 3.15/5. Llama-3.1-70B-Instruct reports 4.95/5 answer relevance, 4.51/5 groundedness, and 3.62/5 combined context relevance. The smaller Llama-3.2-3B-Instruct reports 4.26/5 answer relevance and 4.19/5 groundedness.

The lower context-relevance scores show that retrieved evidence is not equally useful for every alert. The authors associate this with false-positive alerts, IOCs not recognized by VirusTotal, and incomplete CTI coverage for some campaigns. On the 10 simulated alerts, answer relevance and groundedness remain high, and context relevance improves because the simulated alerts are known true positives. The authors also include manual cybersecurity-expert validation; these evaluations are limited to the small simulated-alert set.

5. Key Findings and Results (continued)

Evaluation area	Reported evidence	Interpretation
Real-world alert set	100 enterprise SIEM alerts; Mistral-large mean scores: 4.97 answer relevance, 3.15 combined context relevance, 4.53 groundedness.	Generated answers were highly relevant and grounded, but context retrieval was weaker for some alerts.
Simulated alert set	10 controlled alerts generated using Caldera in an isolated environment.	Known attack scenarios support more direct evaluation of context and response quality.
Evaluation method	Three automated LLM evaluators and manual expert assessment.	Combining automated scoring with expert review provides cross-checking, although the expert sample is small.
CTI coverage	Authors report missing or insufficient context for some IOCs and campaigns.	Retrieval quality depends on the availability and coverage of CTI sources.

6. Limitations and Research Gaps

- Context retrieval is dependent on the coverage and quality of external CTI platforms and the indexed CTI report collection. Alerts whose IOCs are unknown or whose campaigns are poorly documented may receive limited context.
- The controlled evaluation contains 10 simulated alerts, and the expert cross-validation is correspondingly limited in scale. Wider testing across organizations, environments, and attack families would be needed before generalizing operational effectiveness.
- The authors identify the need to incorporate additional trusted private CTI sources and more comprehensive reports to improve context coverage.
- The system generates incident-mitigation strategies. It does not demonstrate recovery-point integrity assessment, backup provenance analysis, quantitative recovery trust scoring, dependency-aware restoration, or post-recovery service validation.

The final point is a project-relevant gap identified by this survey, rather than a limitation explicitly claimed as the paper's primary research question.

7. Relevance to the Proposed Capstone Project

This paper provides a foundation for the incident-understanding stage of Team 221's proposed system. Its hybrid retrieval approach can inform how the project correlates SIEM alerts with external IOC information and historical CTI reports. Its use of grounded response generation also motivates retaining evidence references alongside AI-generated recommendations.

The proposed capstone extends beyond response recommendation. Team 221 intends to connect incident evidence and attack timelines to the assessment of candidate recovery points, calculate a Recovery Trust Score (RTS), classify recovery candidates, and plan restoration according to service dependencies. Policy checks and human approval can constrain high-impact actions, followed by validation of restored services. These are proposed project components and are not methods introduced by Tellache et al.

8. Conclusion

Tellache et al. present a RAG-based approach that enriches SIEM alerts with structured and document-based CTI before generating incident response strategies. Their experiments on real and simulated alerts report strong answer relevance and groundedness, while also exposing the importance of CTI coverage for context relevance. For Team 221, the paper is relevant to evidence-enriched incident analysis; the additional challenge is to use that evidence to assess backup trust and orchestrate safe recovery.

Reference

[1] A. Tellache, A. A. Korba, A. Mokhtari, H. Moldovan, and Y. Ghamri-Doudane, “Advancing Autonomous Incident Response: Leveraging LLMs and Cyber Threat Intelligence,” in *Proceedings of the 2025 IEEE Global Communications Conference (GLOBECOM)*, 2025. DOI: 10.1109/GLOBECOM59602.2025.11432623. Preprint: arXiv:2508.10677v1, 14 Aug. 2025. https://arxiv.org/abs/2508.10677

Prepared for Capstone Project Phase-I · Individual literature survey by Dhruva Hegde.

LITERATURE SURVEY

Trust-Aware Agentic AI for Autonomous Cyber Incident Response and Resilient Recovery

Project ID	Course	Review
221	UE24CS320A – Capstone Project	Phase-I · Review-1
Project Guide	**Institution**	**Survey focus**
Dr. Geetha Dayalan	PES University	Ransomware backup and recovery

Research Paper Under Review
"Amoeba: An Autonomous Backup and Recovery SSD for Ransomware Attack Defense"
Authors: Donghyun Min, Donggyu Park, Jinwoo Ahn, Ryan Walker, Junghee Lee, Sungyong Park, and Youngjae Kim.
Publication: IEEE Computer Architecture Letters, vol. 17, no. 2, pp. 243–246, July–December 2018.
DOI: 10.1109/LCA.2018.2883431.

Abstract of the Survey

This survey reviews Amoeba, an autonomous SSD design that detects potentially ransomware-infected page writes, manages backup copies within the storage device, and supports recovery. The design combines a Ransomware Attack Risk Indicator (RARI), hardware-assisted computation, and a fine-grained backup-management mechanism. The paper is relevant to Team 221 because it demonstrates automated ransomware-aware backup and restoration. Its focus is storage-page protection, rather than enterprise-wide incident analysis or dependency-aware service recovery.

1. Problem Addressed

Ransomware commonly encrypts user data and overwrites the original content. Backups can support recovery, but host-managed or remote backup solutions may introduce storage, performance, and network overhead. They may also be exposed to ransomware or privileged software operating on the host. Earlier SSD-level approaches such as FlashGuard and SSD-Insider have limitations: a simple Read-After-Write pattern can cause unnecessary backups, and repeated backup creation can increase garbage-collection activity and recovery search cost.

The paper addresses how an SSD can autonomously detect suspicious page writes and preserve a useful previous version of data with low overhead. The goal is to perform ransomware detection, backup management, and recovery inside the SSD, reducing dependence on host-side decisions.

2. Proposed Methodology

Amoeba calculates a Ransomware Attack Risk Indicator (RARI) for page-write requests. RARI combines three indicators: write intensity, similarity between old and incoming page content, and entropy. The indicators are normalized using MinMaxScaler and combined through a logistic classification function. The model weights are obtained using logistic regression. Similarity and entropy calculations are assigned to a hardware accelerator implemented by extending the SSD's DMA controller, allowing computation to overlap with data transfer.

Amoeba checks both the Read-After-Write pattern and whether the RARI value exceeds a threshold. When both conditions are satisfied, the write is treated as ransomware-related and the previous page is retained as a backup. The system uses page metadata and a non-deterministic finite automaton (NFA) to manage page states. It maintains at most one backup page for each logical page and uses backup levels to manage backup-space pressure during garbage collection.

2. Proposed Methodology (continued)

Component	Function in Amoeba
RARI indicators	Combines write intensity, content similarity, and entropy to estimate the ransomware risk of a page write.
Logistic classification	Normalizes the indicators and combines them using learned weights and a bias term.
DMA hardware accelerator	Computes similarity and entropy during data transfer to reduce the visible performance cost.
Read-After-Write check	Used together with the RARI threshold; both conditions must be met for a write to be classified as ransomware-related.
NFA page-state model	Represents free, valid, invalid, valid-plus-backup, and recovery states and their transitions.
Backup-space control	Maintains one backup page per logical page and assigns backup levels used during garbage collection.

3. Technologies and Algorithms

The design is based on NAND-flash SSD architecture and the Flash Translation Layer (FTL). It uses a DMA controller extended with RARI computation, MinMaxScaler normalization, logistic regression/classification, content similarity, entropy calculation, write-intensity counting, and an NFA for page-state transitions. Backup metadata is stored in the page's out-of-band (OOB) area. The garbage-collection mechanism considers backup pages and uses backup levels to control storage consumption.

4. Experimental Setup

The authors implement Amoeba and FlashGuard in an extended Microsoft Research DiskSim SSD simulator. A register-transfer-level model is used to measure DMA computation overhead. The workload contains 3,211 files totalling approximately 4.84 GB. Block-level I/O and content traces are collected while running Erebus Linux ransomware and a normal synthetic I/O application. The study compares detection errors, average I/O response time, garbage-collection activity, and recovery search cost.

5. Key Findings and Results

The paper reports that calculating similarity and entropy for an 8 KB page increases DMA transfer latency by approximately 2% compared with conventional DMA. With the evaluated workload, the combined false-positive and false-negative ratio for Amoeba is 2.58%, compared with 27.59% for FlashGuard. This result is attributed to Amoeba combining RARI with the Read-After-Write pattern rather than relying on the pattern alone.

Amoeba's average I/O response time is reported as close to the baseline. FlashGuard's performance degrades as the number of backup pages and SSD occupancy increase, due to additional garbage-collection activity. In the FG(4) comparison, Amoeba's response time is reported as up to approximately 12% higher than FlashGuard's; the paper explains that this comparison reflects Amoeba's more selective backup decision. FlashGuard requires up to four times the recovery search cost compared with Amoeba in the tested scenarios.

5. Key Findings and Results (continued)

Evaluation area	Reported result	Significance
Detection error	Combined false-positive and false-negative ratio: Amoeba 2.58%; FlashGuard 27.59%.	Combining content-derived RARI with I/O pattern detection improves classification in the tested workload.
DMA computation overhead	Approximately 2% increase in 8 KB page-transfer latency.	The hardware-assisted computation has a relatively small measured transfer-latency impact in the experiment.
I/O response time	Amoeba is close to baseline; up to about 12% higher than FlashGuard FG(4) in the cited comparison.	Amoeba limits unnecessary backup creation, but it is not faster than every FlashGuard configuration.
Recovery search cost	FlashGuard requires up to four times more accumulated page-search cost than Amoeba.	Maintaining one backup page per logical page simplifies recovery in the evaluated scenarios.

6. Limitations and Research Gaps

- Amoeba is implemented and evaluated as an SSD-level mechanism. It does not provide an end-to-end enterprise incident-response workflow that combines endpoint alerts, CTI, attack timelines, and business-service recovery.
- RARI is based on page-write characteristics—intensity, similarity, and entropy. It is not a general recovery trust score based on backup provenance, incident chronology, service dependencies, and multiple sources of security evidence.
- The evaluation is simulator-based and uses a specific workload containing 3,211 files and traces collected with Erebus ransomware and synthetic I/O. Results may differ for other storage devices, workloads, ransomware families, or production environments.
- The paper focuses on restoring data pages within the SSD. It does not address dependency-aware restoration of applications and services, policy approval workflows, or post-recovery security and functionality validation.

These broader gaps are identified by comparing the paper's storage-layer scope with the requirements of Team 221's proposed capstone.

7. Relevance to the Proposed Capstone Project

Amoeba is directly relevant to the backup and recovery part of Team 221's research. It demonstrates that backup copies can be managed inside storage hardware and that write-level risk indicators can help decide when to preserve previous data. Its RARI mechanism provides an example of combining multiple signals instead of relying on a single overwrite pattern.

The proposed capstone operates at a broader system level. It can investigate whether recovery candidates should be assessed using incident timelines, CTI, backup metadata, integrity evidence, and service-dependency information. The project-specific Recovery Trust Score (RTS), trust categories, policy gate, dependency-aware recovery planner, and post-restoration validation are extensions proposed by Team 221; they are not components of Amoeba.

8. Conclusion

Min et al. propose Amoeba, an autonomous SSD design that combines RARI-based ransomware detection with fine-grained backup management and recovery. Their simulator-based evaluation reports lower detection error and lower recovery search cost than FlashGuard in the tested workloads, with a small measured DMA latency increase. The work provides a useful storage-level foundation for ransomware resilience, while leaving open the broader challenge of connecting incident evidence to trustworthy recovery-point selection and coordinated restoration of dependent services.

Reference

[1] D. Min, D. Park, J. Ahn, R. Walker, J. Lee, S. Park, and Y. Kim, “Amoeba: An Autonomous Backup and Recovery SSD for Ransomware Attack Defense,” *IEEE Computer Architecture Letters*, vol. 17, no. 2, pp. 243–246, Jul.–Dec. 2018. DOI: 10.1109/LCA.2018.2883431. https://doi.org/10.1109/LCA.2018.2883431

Prepared for Capstone Project Phase-I · Individual literature survey by Dhruva Hegde.